

Appendix E — Data Protection Impact Assessment (DPIA)

Controller: DEQUAD Ltd (in formation), United Kingdom **Processor:** DEQUAD Ltd (in formation)
Processing activity covered: Operation of the DEQUAD platform — verified-student peer matching, daily mood tracking, in-app messaging, safeguarding scanning, and 24/7 support chat. **DPIA version:** v0.4 (draft)
Author: Yusuf Quadri, CEO (acting controller representative) **Reviewed by:** *External fractional DPO to be appointed Month 1 post-endorsement (recommended: The DPO Centre)* **Last reviewed:** _____ **Next review due:** 12 months from approval

E.1 Why this DPIA is required

UK GDPR Art 35 requires a DPIA where processing is **likely to result in a high risk to the rights and freedoms of natural persons**, including:

- Systematic monitoring of behaviour (Art 35(3)(c))
- Processing of special-category data on a large scale (Art 35(3)(b))
- Use of new technologies (Art 35(3))

DEQUAD's processing meets at least two of these criteria — systematic monitoring of in-app behaviour for safeguarding purposes and processing of mental-health (special category) data. A DPIA is therefore mandatory.

E.2 Description of the processing

E.2.1 Nature

DEQUAD collects, stores, analyses, and acts upon data from verified UK university students relating to:

- Identity (name, photo, university email)
- Profile preferences (course, modules, society interests, lifestyle)
- In-app messages
- Daily mood scores and free-text notes
- Support-chat messages

Data is analysed by: - A peer-matching engine (compatibility ranking) - A safeguarding engine (real-time crisis-keyword scanning) - A wellbeing-baseline engine (per-user trend detection) - An LLM-assisted support reply engine (text generation)

E.2.2 Scope

Dimension	Scope at endorsement	Scope at Year 5
Geographic	United Kingdom only	UK + Republic of Ireland + ANZ + Canada
Data subjects	Verified UK HE students	+ FE students + ICB-commissioned 16-25
Volume	0 at endorsement	Up to ~1.2m active users
Retention	See E.5	See E.5
Special-category data	Mental-health (mood, support, safeguarding flags)	Same

E.2.3 Context

DEQUAD is a closed network. Data subjects are adults (16+) who have actively chosen to sign up, have read a plain-English privacy notice, and have given explicit consent to special-category processing where required. The processing is necessary to deliver the product the user has signed up for.

E.2.4 Purposes

Purpose	Lawful basis (Art 6)	Special category basis (Art 9)
Verifying university affiliation	Performance of contract (Art 6.1.b)	n/a
Storing mood entries	Consent (Art 6.1.a)	Explicit consent (Art 9.2.a)
Crisis-keyword scanning	Legitimate interest (Art 6.1.f) + vital interests (Art 6.1.d) where life at risk	Substantial public interest — safeguarding of children and individuals at risk (DPA 2018 Sch 1 Pt 2 para 18)
Peer matching	Performance of contract	n/a
Anonymised research licensing	Legitimate interest (Art 6.1.f)	Data fully anonymised before transfer; not in scope of Art 9

A full data-flow diagram is filed alongside this DPIA as [E_supporting/data_flow.png](#) .

E.3 Consultation

Party consulted	Date	Outcome
The DPO Centre (proposed DPO)	<i>Pending</i>	Fractional DPO retainer to be signed Month 1 post-endorsement
ICO Innovation Hub	<i>Pending</i>	Application to the Innovation Service for early-stage guidance during Month 2
Sample data subjects	<i>Pending — pilot university</i>	User-research interviews planned during pilot onboarding
Independent safeguarding consultant	<i>Pending — proposed: Survivors UK / NSPCC Learning</i>	Annual audit retainer Year 1

E.4 Necessity and proportionality

Test	Assessment
Are the lawful bases identified appropriate?	Yes — consent for mood (revocable), contract for matching, substantial public interest for safeguarding
Does the processing achieve its purpose?	Yes — wellbeing trends and safeguarding alerts cannot be detected without processing the underlying data
Is there a less-invasive way?	Considered: (a) population thresholds instead of per-user baseline (rejected — see Appendix D for evidence of higher false-positive rate); (b) self-report only with no scanning (rejected — fails OSA s. 10 safeguarding duty); (c) hashing of message content (rejected — defeats safeguarding purpose)
Quality and accuracy	Mood data is self-reported (Art 5.1.d compliant — subject to data subject's own veracity); profile data is editable by the user at any time; admin records are auditable
Data minimisation	Profile-photo upload optional; mood-note free-text is optional; no demographic data collected beyond university name unless user explicitly adds it
Retention	See E.5
Rights of data subjects	See E.6
Processors	See E.7

E.5 Retention schedule

Data category	Retention period	Justification
Active account profile	Duration of account + 30 days post-deletion	30-day grace for accidental deletion; compliant with Art 17
Mood entries	Duration of account; user-exportable; user-deletable	User-controlled
In-app messages	Duration of account, both sides; deleted on either party's account deletion (deletion takes precedence)	UK GDPR principle of data minimisation
Safeguarding-alert records	7 years from creation	Required for safeguarding audit trail (Care Act 2014 best practice; statutory limitation for civil claims)
Support-chat transcripts	2 years	Customer-service quality + dispute resolution
Stripe billing records	7 years	Companies Act 2006 + HMRC requirement
Server access logs	90 days	Security; sufficient for incident response
Audit logs (admin actions)	7 years	Internal-control + OSA s. 23 record-keeping

E.6 Rights of data subjects

Right	How exercised	Response SLA
Access (Art 15)	"Download my data" in app + DPO email	30 days
Rectification (Art 16)	Inline profile edits + DPO email	Immediate (UI) / 30 days (DPO)
Erasure (Art 17)	"Delete account" in app + DPO email	30 days; safeguarding records retained per E.5 with lawful basis
Restriction (Art 18)	DPO email	30 days
Portability (Art 20)	"Export my data" in app — JSON file	30 days
Objection (Art 21)	DPO email	30 days
Withdraw consent (Art 7.3)	One-tap revocation in app	Immediate
Lodge a complaint with ICO	Linked from in-app privacy notice and dequad.co.uk/privacy	n/a

A documented Subject Rights Request procedure is maintained at [/internal/SRR_procedure.md](#) (not yet public).

E.7 Processors

Processor	Purpose	Data shared	Location	Contract status
MongoDB Atlas (MongoDB Inc.)	Database hosting	All collections	UK (London region)	Atlas DPA accepted; Standard Contractual Clauses adopted
Stripe Payments UK Ltd	Subscription billing	Email + payment token	UK	Stripe DPA accepted
Cloudflare UK Ltd	DNS / WAF / CDN	IP + request metadata	UK / EU	Cloudflare DPA accepted
OpenAI (via Emergent LLM Key)	LLM auto-reply on support chat	Redacted excerpt of support text only	US (with Standard Contractual Clauses)	Emergent ToS + OpenAI DPA
Expo Push Service (Expo Inc.)	Push notifications	Device token + alert payload	US (with SCCs)	Expo DPA
Sentry (Functional Software Inc.)	Error monitoring	Stack traces (PII-scrubbed)	EU region	Sentry DPA
AWS SES (Amazon Web Services EMEA)	Transactional email	Email address + body	UK (eu-west-2)	AWS DPA accepted
Hiscox / Markel	Insurance	None during ordinary course	UK	n/a

International transfers documented in `E_supporting/transfer_register.md` with Standard Contractual Clauses 2021 in place where applicable.

E.8 Risk register

#	Risk	Likelihood	Severity	Inherent risk	Mitigation	Residual risk
1	Unauthorised access to mood/safeguarding records	Low	High	High	Encryption at rest + TLS in transit + RBAC + audit logging + annual pen-test	Low
2	Re-identification from "anonymised" research data	Med	High	High	k-anonymity ≥ 5 enforced; named DPO review of every release; written agreements with recipients	Low
3	Excessive scanning of in-app messages (over-collection)	Med	Med	Med	Keyword library reviewed quarterly; false-positive rate audited; transparency report annually	Low
4	LLM prompt-injection or output containing PII	Med	Med	Med	All user text redacted before LLM call; no PII in prompt templates; output filtered for crisis numbers + URLs only	Low
5	Cross-border transfer to OpenAI (US)	Med	Med	Med	Only redacted excerpts; SCCs in place; transfer-risk assessment lodged at E_supporting/transfer_risk_assessment.md	Low-Med
6	Data subject denied erasure due to safeguarding retention	Low	High	Med	Lawful basis (substantial public interest) documented per request; data subject notified in writing with right to ICO complaint	Low
7	Insider misuse of admin dashboard	Low	High	Med	Two-factor auth on admin; audit log retained 7 years; quarterly access review; immediate offboarding workflow	Low
8	DPIA itself becomes stale	High	Med	Med	DPIA reviewed annually and on any material change (e.g. new processor, new processing purpose)	Low
9	Children (under-18) processed without parental consent	Low	High	Med	Birth-date check at sign-up; flag for .ac.uk accounts where birth-date < 18; default privacy-protective settings; ICO AADC alignment	Low
10	A safeguarding event leaks to other students	Low	Critical	High	Safeguarding scans are server-side only; alerts go to DSL email, never in-app; UI design prevents accidental exposure	Low

E.9 Approvals

Role	Name	Signature	Date
Controller representative	Yusuf Quadri	<i>signed in original</i>	_____
Data Protection Officer	<i>The DPO Centre (designated)</i>	<i>to follow Month 1</i>	_____
External safeguarding advisor	<i>to be appointed Year 1</i>	<i>to follow</i>	_____

E.10 Conclusion

The processing described above is necessary to deliver the DEQUAD service and to meet UK regulatory obligations under the Online Safety Act 2023. The risks have been identified and mitigated to a level that — in the controller's view — meets the UK GDPR Article 35 standard of being **proportionate to the purposes and rights at stake**. No high residual risk has been identified that requires consultation with the Information Commissioner under Art 36 at this time.

The DPIA will be re-reviewed annually, on the appointment of the DPO, and immediately upon any material change in processing.